

****03.11.2023****

****Sanction for GDPR Violation****

The National Authority for the Supervision of Personal Data Processing completed an investigation in October 2023 regarding the operator OTP BANK ROMANIA SA and found a violation of the provisions of Article 32 and Article 33 of Regulation (EU) 2016/679.

As such, the operator was sanctioned administratively:

- with a fine of 14,889.3 lei (equivalent to 3,000 EURO) for the violation of Article 32 of Regulation (EU) 2016/679;
- with a warning for the violation of Article 33 of Regulation (EU) 2016/679.

During the investigation conducted by the supervisory authority, which was carried out based on a complaint, it was found that the operator did not adopt sufficient security measures in accordance with Article 32 of the GDPR, which led to the occurrence of a security incident, through the transmission via email of the personal data of the complainant to another person.

Additionally, it was found that OTP Bank Romania SA did not notify the National Authority for the Supervision of Personal Data Processing about the security incident that affected the personal data of the complainant, thus violating Article 33 of the GDPR.

The National Authority for the Supervision of Personal Data Processing also applied corrective measures, ordering the operator to:

- ensure compliance with the GDPR for personal data processing operations by implementing appropriate technical and organizational security measures specific to the nature of the processing and the identified risks, throughout the entire data processing cycle, particularly regarding the verification of the accuracy of the processed personal data, the establishment of appropriate rules related to the drafting and management of files that may be transmitted using electronic communication means (remotely), the training of individuals processing data under its authority, the regular verification of compliance with the instructions given to them, and the automation of certain processes to reduce the risks of illegal or unauthorized processing of personal data;
- ensure compliance with the GDPR for personal data processing operations by adopting necessary internal measures for the rapid detection, management, and reporting of situations involving breaches of personal data security (whether or not they require notification to the supervisory authority and/or the data subjects), as well as through appropriate and regular training of individuals processing data under the authority of the operator.

****Legal and Communication Department****

****N.A.S.P.D.C.P.****